

Corporate Office Network Security Documentation

Company Profile: Mid-sized company with 150 employees

Departments: HR, Finance, IT

Date: December 2025

1. Network Architecture Overview

This network design implements a secure, segmented architecture that protects company resources while enabling efficient operations and remote access for employees.

Key Design Principles:

- **Defense in Depth:** Multiple layers of security controls
 - **Network Segmentation:** VLANs isolate departments
 - **Least Privilege:** Access granted based on role requirements
 - **Secure Remote Access:** Encrypted VPN for remote workers
-

2. Network Components

2.1 Security Devices

Main Firewall

- **Model:** Enterprise-grade next-gen firewall
- **Location:** Network perimeter (between internet and internal network)
- **IP Address:** 203.0.113.1 (external), 10.0.0.254 (internal)
- **Function:** Traffic filtering, NAT, deep packet inspection
- **Rules:** Default deny inbound, content filtering outbound

VPN Gateway

- **Location:** Behind main firewall
- **IP Address:** 10.0.0.250
- **Protocols:** IPSec and SSL VPN

- **Authentication:** Two-factor authentication (2FA) required
- **Encryption:** AES-256

IDS/IPS System

- **Location:** Inline with core network traffic
- **IP Address:** 10.0.0.240
- **Function:** Real-time threat detection and blocking
- **Monitoring:** 24/7 automated alerts for suspicious activity

2.2 Network Infrastructure

Core Router

- **IP Address:** 10.0.0.1
- **Function:** Inter-VLAN routing, gateway for all internal traffic
- **Routing Protocol:** OSPF
- **Features:** QoS enabled for voice/video traffic

Layer 3 Switch

- **Management IP:** 10.0.0.2
- **Function:** VLAN creation and management, internal switching
- **VLANs Configured:**
 - VLAN 10 (HR)
 - VLAN 20 (Finance)
 - VLAN 30 (IT)
 - VLAN 100 (Servers)

2.3 Server Infrastructure

Active Directory Server

- **IP Address:** 10.0.100.10
- **OS:** Windows Server 2022
- **Function:** Centralized authentication, group policies, user management
- **Backup:** Daily incremental, weekly full

File Server

- **IP Address:** 10.0.100.20
- **OS:** Windows Server 2022
- **Storage:** 10TB RAID 6
- **Function:** Shared file storage for all departments
- **Access Control:** Based on AD security groups

Email Server

- **IP Address:** 10.0.100.30
- **Software:** Microsoft Exchange Server
- **Function:** Internal and external email communication
- **Security:** Anti-spam, anti-malware scanning

Backup Server

- **IP Address:** 10.0.100.40
 - **Function:** Automated daily backups of all servers and critical data
 - **Retention:** 30 days onsite, 90 days offsite
-

3. Network Segmentation (VLANs)

VLAN 10 - HR Department

- **Network:** 10.0.10.0/24
- **Gateway:** 10.0.10.1
- **DHCP Range:** 10.0.10.100 - 10.0.10.200
- **Devices:** 15 workstations, 1 wireless access point
- **Access Rules:**
 - Can access: Email server, file server (HR folder only), internet
 - Cannot access: Finance or IT department resources

VLAN 20 - Finance Department

- **Network:** 10.0.20.0/24
- **Gateway:** 10.0.20.1
- **DHCP Range:** 10.0.20.100 - 10.0.20.200
- **Devices:** 20 workstations, 1 wireless access point
- **Access Rules:**
 - Can access: Email server, file server (Finance folder only), internet, accounting software
 - Cannot access: HR or general IT resources
 - **Extra Security:** Enhanced logging, MFA required for financial applications

VLAN 30 - IT Department

- **Network:** 10.0.30.0/24
- **Gateway:** 10.0.30.1
- **DHCP Range:** 10.0.30.100 - 10.0.30.200

- **Devices:** 15 workstations, 1 wireless access point
- **Access Rules:**
 - Full network management access
 - Can access all VLANs for support purposes
 - Administrative access to all servers and network devices

VLAN 100 - Server Network

- **Network:** 10.0.100.0/24
 - **Gateway:** 10.0.100.1
 - **Static IPs:** All servers use static addressing
 - **Access Rules:**
 - Accessible from all department VLANs based on ACLs
 - No direct internet access (protected behind firewall)
-

4. Security Policies and Controls

4.1 Firewall Rules

Inbound Rules (from Internet):

1. **DENY ALL** by default
2. **ALLOW** VPN traffic (UDP 500, 4500 for IPSec)
3. **ALLOW** Email (SMTP/TLS port 587, IMAP port 993)
4. All other traffic blocked

Outbound Rules:

1. **ALLOW** HTTP/HTTPS (ports 80, 443) with content filtering
2. **ALLOW** Email protocols
3. **ALLOW** DNS (port 53)
4. **BLOCK** Known malicious IPs (threat intelligence feed)
5. **LOG** all denied connection attempts

4.2 Access Control Lists (ACLs)

Inter-VLAN Communication:

- HR cannot communicate with Finance or IT VLANs
- Finance cannot communicate with HR or IT VLANs
- IT can communicate with all VLANs (for support)
- All VLANs can access server VLAN for authorized services

Server Access:

- Active Directory: Accessible from all VLANs (authentication)
- File Server: Role-based access controlled by AD groups
- Email Server: Accessible from all VLANs
- Backup Server: IT department only

4.3 Authentication and Access Control**User Authentication:**

- All users authenticate via Active Directory
- Password policy: Minimum 12 characters, complexity required, 90-day expiration
- Account lockout: 5 failed attempts = 30-minute lockout
- MFA required for:
 - VPN access
 - Financial applications
 - Administrative accounts

Wireless Security:

- WPA3-Enterprise authentication
- 802.1X with RADIUS (using Active Directory)
- Separate SSIDs per department
- Guest network isolated from corporate network

4.4 Data Protection**Encryption:**

- VPN: AES-256 encryption for all remote connections
- Wireless: WPA3 encryption
- File Server: BitLocker encryption at rest
- Email: TLS encryption in transit

Backup Strategy:

- Automated daily incremental backups at 2:00 AM
- Weekly full backups on Sundays
- 30-day retention on local backup server
- Monthly offsite backups for disaster recovery
- Regular backup restoration tests (quarterly)

4.5 Monitoring and Logging

IDS/IPS Monitoring:

- Continuous traffic analysis
- Automated threat blocking
- Alert notifications for security team
- Weekly report generation

Log Management:

- All firewalls, routers, switches log to central server
 - Logs retained for 90 days
 - Daily review of security events
 - Automated alerts for critical events:
 - Multiple failed login attempts
 - Unauthorized access attempts
 - Network anomalies
 - System configuration changes
-

5. Remote Access Security

VPN Configuration

Remote Worker Requirements:

1. Install company-approved VPN client
2. Use company-issued laptop or approved personal device
3. Enable two-factor authentication (authenticator app)
4. Must accept latest security patches

VPN Access Process:

1. User enters username and password
2. User enters 6-digit code from authenticator app
3. VPN establishes encrypted tunnel
4. User assigned IP from 10.0.50.0/24 range
5. Access granted based on AD group membership

Security Features:

- Split tunneling disabled (all traffic through VPN)
- Automatic disconnect after 8 hours
- Re-authentication required after disconnect
- Device compliance check before connection

6. Incident Response Plan

Detection

- IDS/IPS alerts security team
- Users report suspicious activity to IT helpdesk
- Automated log analysis identifies anomalies

Response Steps

1. **Contain:** Isolate affected systems/VLANs
2. **Investigate:** Analyze logs and determine scope
3. **Eradicate:** Remove threat and patch vulnerabilities
4. **Recover:** Restore systems from clean backups
5. **Document:** Record incident details and lessons learned

Key Contacts

- IT Manager: [Contact info]
 - Network Administrator: [Contact info]
 - Security Team: security@company.com
 - External IT Security Consultant: [Contact info]
-

7. Maintenance and Updates

Regular Maintenance Schedule

Daily:

- Monitor IDS/IPS alerts
- Check backup completion status
- Review critical security logs

Weekly:

- Review firewall logs
- Check for security updates
- Verify backup integrity

Monthly:

- Update firewall rules as needed
- Review user access permissions
- Patch servers and network devices
- Test backup restoration

Quarterly:

- Security audit
- Penetration testing
- Review and update documentation
- Security awareness training for employees

Annually:

- Full security assessment
 - Disaster recovery drill
 - Review and update security policies
-

8. Compliance and Best Practices

Standards Followed:

- NIST Cybersecurity Framework
- ISO 27001 principles
- Industry best practices for network segmentation

Security Best Practices Implemented:

- ✓ Network segmentation with VLANs
 - ✓ Defense in depth strategy
 - ✓ Least privilege access control
 - ✓ Encrypted remote access
 - ✓ Regular backups and testing
 - ✓ Continuous monitoring and logging
 - ✓ Incident response plan
 - ✓ Regular security updates and patches
 - ✓ Employee security awareness
-

Document Control

Version: 1.0

Last Updated: December 2025

Next Review: March 2026

Maintained by: Marco

Approved by: Marco